Security status: patientportalapi

Branch `mohan-staging-security`, updated 2026-11-03. Compared against `main`.

No endpoint or socket event was removed. All 175 routes and all 15 socket events on `main` still exist. Code that had to stop running was commented out, moved, or put behind auth, not deleted. Main's prescription email fix (commit `064d732`) is included.

Most fixes keep the request and response formats the frontends use today. The exceptions are listed in Behaviour the frontends may notice.

1. Fixed

Auth, sessions, crypto

Issue	Fix	Where
6 auth endpoints deleted by the first audit (`/register`, `/encrypt`, `/decrypt`, `/getquery`, `/ssologin`, `/external-signup-old`)	Restored with their code, now only callable with the `x-sync-api-key` header	`routes/authRoutes.js`, `controllers/authController.js`, `services/authService.js`
Password-reset race: anyone could finish a reset once the victim verified the OTP	The reset now needs the same IP that verified the OTP, or the new `resetToken` that verify-otp returns	`helpers/otpHelper.js`, `services/forgotPasswordService.js`
Resending an OTP reset the wrong-guess counter	Max 10 failures per email per hour, kept across resends; no new OTP is sent while locked	`helpers/otpHelper.js`
send-otp answered slower when the account exists (reveals accounts)	Email is sent without waiting	`services/forgotPasswordService.js`
A care navigator acting as a patient could change that patient's password	Tokens from care-navigator sign-in carry `act: 'careNavigator'` and cannot change passwords. The sign-in is logged.	`careNavigatorController.js` login, `authController.js` sso-generate-code, `forgotPasswordService.js`
HR "disable employee" did not stop the employee logging in	Patients with `is_active = 0` can no longer log in	`services/authService.js`
A deleted or inactive HR user's token kept working	`jwtAuthHr` loads the HR row on every request	`middleware/jwtAuthHr.js`, `hrController.js`
AES key, IV, plaintext and ciphertext printed to the logs	Those log lines are commented out	`config/encryption.js`
Patient name, email, phone, DOB and address written to the logs table	Added to the redaction list	`helpers/redact.js`
Full patient rows, including the password hash, logged with `console.log`	Commented out	`appointmentService.js`, `hrController.js`, `PreEmployeePatientService.js`
Login and OTP endpoints accepted 50 MB bodies	100 KB limit on those paths	`index.js`
Localhost allowed as a browser origin in production	Removed from the default list when `NODE_ENV=production`	`index.js`, `socket/index.js`

Issue	Fix	Where
Encryption algorithm undefined when `ALGORITHM` is not set	Defaults to `aes-256-cbc`	`config/encryption.js`
`generateVerificationLink` used `jwt` without importing it	Import added	`helpers/commonHelper.js`

Access to other users' data

Issue	Fix
`GET /api/prescription`: any doctor could read any patient's PHI and records by email or call id	The doctor must be linked to the patient through a call, appointment or care team, and the call must belong to the patient (`PatientService.isDoctorLinkedToPatient`)
`POST /api/prescription/detail`: any doctor could overwrite another doctor's prescription	The appointment must belong to the doctor. The patient comes from the appointment. Another doctor's row is never updated.
`POST /api/appointment/book`: client-sent `is_paid`, any doctor id allowed	`is_paid` is set by the server from a verified payment. The doctor must belong to one of the patient's companies.
Lab order price checked against any lab's price list	The check is limited to the order's lab
`POST /api/labs/labtestnotification`: a patient could trigger fake status emails	The order must be the caller's own and its real status is used. Only known statuses are accepted, max 5 per 10 minutes.
Vitals comment author set by the client	Only the patient, or a care navigator of the patient's company
Dependents: no validation, and removing one dependent deleted all of them (data loss)	Item schema added. An email cannot be changed to one already used. Only the removed dependents are deleted.
`profile_image` accepted any URL	Must be one of our uploads (stored images still accepted)
Dependent invite link put the email into the URL unencoded	`encodeURIComponent`
Care navigators could set any status or URL (`javascript:`, phishing) on lab orders, reports and prescriptions	Status allow-list. URLs must be https on our upload host (`UPLOAD_ALLOWED_HOSTS` adds more).
Any portal user could upload into any folder (`hr`, `prescription`, ...)	Allowed folders per role, matching what each portal sends
HR add-employee had no validation	Joi schema, checked after auth
Migration endpoints accepted any number of records	Capped (`MAX_MIGRATION_RECORDS`, default 5000)
Unrouted HR `login` could log in as any patient if it were ever routed	Disabled with `ALLOW_UNSCOPED_LOGIN = false`; its code is kept

Realtime and chat

Issue	Fix
Incoming-call events with patient name, email and phone sent to every doctor	Only sent to the targeted doctors (`connect:<id>` rooms)
Socket stayed connected after the token expired	Disconnected at token expiry
No limits on chat messages	Max 5000 chars, `messageType` 1 or 2 only, 20 messages per 10 seconds, 100 KB socket buffer
Any doctor could chat with any care navigator	Only when they share a company (`doctor_employer`)

Issue	Fix
Chat search listed every doctor and navigator; user-status showed anyone's online state	Limited to people the caller is allowed to chat with
SQL built with string interpolation in `getChatList`	Uses replacements

Dependencies

- Removed the unused packages `html-pdf` and `bcrypt`. Nothing `require`s them, and they were the source of all 3 critical advisories.
- Upgraded `nodemailer` from 6 to 10.3.1 (SMTP header injection fixes) and `puppeteer` from 23 to 24.43.1.
- Updated `joi`, `express`, `body-parser`, `follow-redirects`, `sequelize`, `opentok` and `axios` within their current major versions.
- `npm audit --omit=dev`: from **34 issues (3 critical) to 18 (0 critical)**. What's left:
  - `@puppeteer/browsers` dependencies (`basic-ftp`, `extract-zip`, `zod`): fixed only in puppeteer 25, which needs Node 22.
  - `uuid` through `sequelize` and `opentok`: `@vonage/jwt` is pinned because newer versions need ESM-only uuid.

2. Open: needs a decision from you

#	Issue	Why it's not fixed	Proposal
D1	**HR-created and migrated patients share the default password** `Akosmd@123`, and nobody has to change it	Product flow: employees are told this password	Create accounts with a random password and email a set-password link (forgot-password flow). It can already be overridden with `DEFAULT_PATIENT_PASSWORD` in `.env`.
D2	**The client sets the call price** (`/labs/create-payment-call`, `total_price`)	The server has no price source. "Call now" uses 249 hardcoded in the frontend; booked calls don't send `doctorId`.	Add a call price to the company or config, and have the frontend send `doctorId` so `doctor_fees` can be used
D3	**Payment for calls is never checked on the server**	The call starts over the socket, and `payment_for_call` has no "used" column	Add a `consumed` / `call_id` column and check it in `incomingCallTalkToDoctor` when the company requires payment
D4	HR can see employees' lab report links (`GET /api/hr/labTests`)	Removing the field changes the HR UI	Return `reportAvailable` instead of the URL
D5	Pre-employee PHI returned unencrypted (`/careNavigator/preemployeelabTests`, `/updatePreLabReport`)	The care navigator frontend expects plain JSON	Switch to `sendSuccess` and update the frontend together
D6	DOB sent to HR as `request_date` / `schedule_date` (`/hr/assesmentHra`)	Changes the HR UI	Use `created_at`
D7	Unsalted MD5 passwords	Shared tables with other systems	Phase 1: a bcrypt(md5) copy in a new table this API owns. Phase 2: the other systems switch over.
D8	Static IV and no MAC on the app-layer encryption	Frontends use the IV from env	Random IV per message (the response already carries `IV`), then AES-GCM in a coordinated frontend release
D9	Logged-in password change needs no current password	All 3 portals would have to send `currentPassword`	Require it in a frontend release

#	Issue	Why it's not fixed	Proposal
D10	Tokens can't be revoked (1-day life)	Needs a password-changed timestamp check	Add `pwdAt` to the token and compare it in `verifyLoginToken`
D11	Prescription link to prescription.akosmd.in uses reversible XOR	That site must change too	HMAC-signed, expiring token
D12	Self-signup into a company by guessing its 6-digit `employer_id` when the domain check is off	Product rule	Require the domain check or an invite code
D13	`/labs/paymentStatusMobile` rejects Razorpay's own callback (functional bug, already present on main)	Fixing it needs the route to accept unencrypted form posts	Remove `validateDataEncryption` on that route; the handler already checks the HMAC signature
D14	Pre-lab report status emails never send (`updateData.status` is never set)	Fixing it starts sending emails	Pass `status` from the controller

3. Open: needs ops or infra action (not code)

#	Action	Urgency
O1	**Key/IV: partly done 2026-11-03.** New random `DATA_ENCRYPTION_KEY` / `DATA_ENCRYPTION_IV` in the *local* `.env` of patientportalapi and doctorportalapi. Not done yet: the server `.env` files; the 5 frontends (`REACT_APP_ENCRYPTION_KEY` / `_IV`, rebuild needed); akos-ohcapi (key hardcoded in `config/encryption.js`). All must switch at the same time. The key is in the public browser bundle, so it is not a real secret; HTTPS is what protects this traffic. **Bitly:** the token is unused in code (the call is commented out). Revoke it in the Bitly dashboard.	**Critical**
O2	**Revoke the SendGrid key** in git history (`routes/SignupController.php`, commits `0e296a1`, `9215198`)	**Critical**
O3	**About 568 patient files (prescription PDFs and more) are committed under `assets/` and served without auth.** 365 legacy prescriptions have sequential names (`prescription_10000.pdf` ...). Move them out of git and the web root, rename the legacy files, and serve them through an authenticated route. Do this together with the deploy process: if production deploys with `git pull`, untracking them would delete the files on the server.	**Critical**
O4	Purge secrets and PHI from git history (`git filter-repo`), then everyone re-clones	**High**
O5	Delete `.env.bak-security` (a second plaintext copy of the secrets) after rotating	**High**
O6	Bind the app to `127.0.0.1` or firewall port 3001 so only nginx can reach it. Otherwise `X-Forwarded-For` can be spoofed past the rate limits and the IP whitelist. Set `TRUST_PROXY` to match.	**Medium**
O7	Set `NODE_ENV=production` in production (enables the stricter CORS default)	**Medium**
O8	Move the in-memory OTP, rate-limit and SSO-actor state to Redis if the API runs more than one process	**Medium**
O9	Move the runtime `ALTER TABLE` (migration service) and `sequelize.sync()` into real migrations, and drop DDL rights from the app DB user	**Low**
O10	Stray tracked files that nothing `require`s: `*_555`, `*_222`, `routes/labTestController.js`, `index.js.save`, `test-*.js`, `deletem.txt`, `index.html`. Kept as asked; remove them when you're ready.	**Low**

Behaviour the frontends may notice

- **Password reset:** must finish from the same IP that verified the OTP, unless the frontend sends back the new `resetToken`, which is recommended.
- **Patient login:** employees disabled by HR can no longer log in. Deleted or inactive HR users get 401 on every HR route.

- **Care navigator acting as a patient:** the token is valid for 2 hours instead of 1 day, and it cannot change the patient's password.
- **Doctors:**
  - Get 403 on patients they have no call, appointment or care-team link with.
  - Each doctor only receives incoming-call events for their own connect ids.
- **Chat:**
  - A doctor and care navigator can only chat when they share a company.
  - Chat search only shows people the caller can chat with.
- **Bookings and uploads:**
  - Booking a doctor outside the patient's companies returns 403.
  - A lab cart priced from a different lab than the order's lab gets "prices changed".
  - Upload `type` is limited per role; all values the current portals send still work.
  - A new `profile_image` URL that is not one of our uploads returns 400.

How this was checked

- `node --check` passes on every changed file.
- All route files and `socket/index.js` load with a dummy env.
- Compared against `main`: no route, socket event or class method is missing.
- Not yet run against a database: the new SQL (doctor-patient link, chat partners, paid-booking check). **Test on staging before deploying.**